

نطاق نظام إدارة أمن المعلومات وبيان التطبيق (ISO/IEC 27001:2022)

القسم 04-ksa-compliance النوع document الحالة draft المالك Founder آخر تحديث 18-08-2026

هذه وثيقة جاهزية وتأسيس، وليست ادعاءً بالحصول على الشهادة. فلاي قাকা (Fly GACA) غير حاصلة على شهادة ISO/IEC 27001 ولا تقدم نفسها كذلك. تستهدف وثيقة `information-security-policy.docx` إجراء تقييم جاهزية ISO 27001 في السنة الثانية (2027)، بما يتوافق مع `compliance-roadmap.md`. تهدف هذه الوثيقة إلى بدء العمل من نطاق محدد وقائمة ضوابط واضحة بدلاً من البدء من الصفر — ولتزويد عملاء B2B والمستثمرين الذين يسألون "ما هو نطاق نظام أمن المعلومات لديكم؟" بإجابة موثقة ودقيقة اليوم.

الحصول على ISO/IEC 27001 طوعي. بينما يظل نظام حماية البيانات الشخصية (PDPL) والأنظمة الصادرة عن سدايا (SDAIA) هي الأطر الملزمة قانونياً.

1. سبب وجود هذه الوثيقة مع وجود سياسة أمن المعلومات

تُعد `information-security-policy.docx` سياسة شاملة ومفصلة من 15 قسمًا — تغطي تصنيف الأصول، التحكم في الوصول، التشفير، الأجهزة الطرفية، الشبكات، تصنيف شدة الحوادث، النسخ الاحتياطي، والتدريب. إنها سياسة متكاملة.

لكنها ليست نظام إدارة أمن معلومات (ISMS) متكاملًا. يتطلب معيار ISO متطلبات إضافية تشمل:

بند معيار ISO	المخرج المطلوب	متوفر قبل هذه الوثيقة
4.3	بيان محدد لنطاق النظام	لا
6.1.2	منهجية موثقة لتقييم المخاطر ومخارجها	لا
6.1.3 / الملحق أ (Annex A)	بيان تطبيق الضوابط (Statement of Applicability)	لا

هذه العناصر الثلاثة هي تحديدًا ما تطلبه الجهات الخارجية والمستثمرون. توفر هذه الوثيقة العنصرين الأول والثالث؛ بينما توفر وثيقة `cyber-risk-assessment-2026-08.md` العنصر الثاني.

2. البند 4.3 — بيان النطاق

يشمل نظام إدارة أمن المعلومات تصميم وتطوير وتشغيل منصة فلاي قাকা (Fly GACA) التعليمية للطيران: تطبيق الويب `flygaca.com` وبوابته الخلفية على `firebase cloud functions`؛ وخدمة الكابتن عادل للذكاء الاصطناعي على `captadel.com`؛ وبيئة `google cloud` الداعمة (قاعدة بيانات `firestore`، المصادقة، دوال الحوسبة، واستدلال نموذج Gemini)؛ ومستودعات الشيفرة البرمجية ومسارات البناء والنشر المستمر (CI/CD) التي تبني هذه الأنظمة وتنشرها. ويغطي النظام كافة البيانات الشخصية للمتعلّمين والمتدربين في الأكاديميات الشريكة التي تعالجها تلك الأنظمة.

الاستثناءات مع التبرير:

البند المستثنى	مبرر الاستثناء
ال خادم الافتراضي في الاتحاد الأوروبي (Hostinger, Paris)	يخدم فهرس اللوائح العامة فقط؛ ولا يعالج أي بيانات شخصية إطلاقاً (<code>06-operations-it/hosting-facts.md</code>)
بيئة بيانات حاملي البطاقات لدى ميسر (Moyasar)	تشغلها شركة ميسر بصفتها معالج دفع ممثل لمعيار PCI DSS؛ ولا تقوم فلاي قাকা بتخزين أو معالجة أو نقل أي من بيانات حاملي البطاقات (<code>pci-dss-scope-and-saq-determination.md</code>)
عمليات الدفع عبر Apple IAP / RevenueCat	تشغلها شركة Apple؛ وتقع خارج حدود التحكم الخاصة بفلاي قাকা
المقرات والمباني ومراكز البيانات الفعلية	لا تدير الشركة أي مقرات أو مراكز بيانات فعلية؛ وجميع البنى التحتية مستضافة سحابياً (وهو ما يفسر استثناءات الملحق A.7 أدناه)

تنويه بنطاق المعالجة الحالية: تعمل الحوسبة حالياً في منطقة `me-central1` (الدوحة) بينما البيانات مخزنة في `me-central2` (الدمام). هذا الوضع يقع ضمن نطاق نظام أمن المعلومات، وهو وضع مؤقت ومقبول بخطة هجرة موثقة، ويتابع تحت بند الخطر CR-09.

3. البند 6.1.2 — منهجية تقييم المخاطر

موضحة بالتفصيل في `cyber-risk-assessment-2026-08.md` المستندة إلى NIST SP 800-30 Rev 1 ومقياس 5-1 للاحتمالية والأثر بما يتطابق مع `09-investor-relations/risk-register.xlsx`.

4. بيان التطبيق (Statement of Applicability)

أعاد تحديث ISO/IEC 27002:2022 هيكلية الملحق أ (Annex A) إلى 93 ضابطاً عبر أربعة محاور. حالات التطبيق: مطبق (Implemented)، جزئي (Partial)، مخطط (Planned)، غير منطبق (N/A) (مع التبرير الإلزامي).

4.1 ملخص التغطية

المحور	عدد الضوابط	مطبق	جزئي	مخطط	غير منطبق
A.5 التنظيمي (Organizational)	37	21	9	5	2

المحور	عدد الضوابط	مطبق	جزئي	مخطط	غير منطبق
A.6 الأفراد (People)	8	4	2	1	1
A.7 المادي (Physical)	14	1	0	0	13
A.8 التقني (Technological)	34	16	10	8	0
المجموع	93	42	21	14	16

4.2 الضوابط غير المنطبقة ومبرراتها

الضابط/الضوابط	مبرر عدم الانطباق
A.7.1–A.7.6, A.7.8, A.7.11–A.7.14 (13 ضابطاً من A.7)	لا تدبر الشركة مكاتب أو مرافق أو مراكز بيانات فعلية. لا توجد حدود أمنية مادية أو معدات موقعية أو وسائط تخزين داخلية للتخلص منها. البنية التحتية بالكامل سحابية وتغطيها شهادات المزودين المعتمدة
A.6.4 الإجراءات التأديبية	لا يوجد موظفون حالياً. يصبح منطبقاً عند أول توظيف
A.5.9 (نطاق جزئي)	ينطبق حصر الأصول على الأصول السحابية والمعلوماتية فقط

يظل الضابط A.7.7 (المكتب النظيف والشاشة النظيفة) مصنفاً ك مطبق لانطباقه على محطة عمل المؤسس المشمولة بالنطاق.

وثائق ذات صلة: `pci-dss-scope-and-saq-determination.md` , `cyber-risk-assessment-2026-08.md` , `01-governance/SECURITY.md` , `information-security-policy.docx`